המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 17/09/2024 שעת הבחינה: 15:00
שנה"ל: תשפ"ד סמסטר: קיץ מועד: א'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 15:20, 15:50. לזכאי תוספת זמן גם בשעה 16:20

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בטופס זה, סעיף א הוא התשובה הנכונה בכל הסעיפים

<u>שאלה מספר 1:</u>

איזו מהטענות הבאות נכונה בהקשר של Certificate Transparency (CT)?

א. CT מחייב את הCAים לרשום כל תעודה דיגיטלית אצל Logger, כך שניתן יהיה לזהות ולחקור תעודות לא תקינות (תעודות שהן Fraudulent).

ב. CT מחייב את הCAים לרשום כל תעודה דיגיטלית אצל Monitor, כך שניתן יהיה לזהות ולחקור תעודות לא תקינות (תעודות שהן Fraudulent).

ג. CT מחייב את הLoggerים לרשום כל תעודה דיגיטלית אצל Monitor, כך שניתן יהיה לזהות ולחקור תעודות לא תקינות (תעודות שהן Fraudulent).

ד. CT מחייב את הMonitorים לרשום כל תעודה דיגיטלית אצל הCAים, כך שניתן יהיה לזהות ולחקור תעודות לא תקינות (תעודות שהן Fraudulent).

<u>שאלה מספר 2:</u>

אליס רוצה לשלוח הודעות לבוב ולקרול אשר יתקיימו בהן גם תכונת ה integrity וגם תכונת ה authenticity. (לא מעניין את אליס סודיות)

כעת נתאר כיצד אליס שולחת הודעה לבוב. שליחה לקרול היא אותו דבר, רק שבכל מקום בתיאור שכתוב בוב, יש להחליף את בוב בקרול. (למשל, אם כאשר אליס שולחת הודעה לבוב היא משתמשת במפתח פומבי של בוב, אז כאשר אליס שולחת לקרול היא משתמשת במפתח הפומבי של קרול וכו').

- **ראשית, אליס בוחרת לכל הודעה בנפרד מפתח סימטרי K אקראי וארוך.**
- **אליס שולחת לבוב הודעה M ובנוסף לשליחת ההודעה M מצרפת גם:**
- **$MAC_K(M)$ (כלומר, את הפלט של ביצוע MAC בעזרת המפתח K על ההודעה M)**
- **$Enc_{PK_B}(K)$ (כלומר, תוצאת ההצפנה <u>של</u> המפתח K, כאשר ההצפנה הינה הצפנה א-סימטרית בעזרת המפתח הפומבי האמיתי של בוב.)**
- **$Sign_{SK_A}\left(hash(K)\right)$ (כלומר, חתימה דיגיטלית <u>על</u> תוצאת ביצוע $hash$ <u>על</u> K, כאשר החתימה מבוצעת בעזרת המפתח הפרטי של אליס)**

נתון כי בוב וקרול יודעים את המפתח הפומבי האמיתי של אליס, ואלגוריתמי ה MAC, ההצפנה, החתימה וה $hash$ המצויינים בשאלה בטוחים.

מהי הטענה הנכונה מבין הבאות?

א. צורת הפעולה של אליס המתוארת בשאלה אינה מבטיחה את תכונת ה authenticity, כי לאחר שבוב יקבל הודעה מאליס הוא יוכל לגרום לקרול לחשוב שאליס שלחה לקרול הודעה שאליס לא שלחה כלל.

ב. צורת הפעולה של אליס המתוארת בשאלה מבטיחה את תכונת ה integrity וגם תכונת ה authenticity, אבל לא מבטיחה סודיות.

ג. צורת הפעולה של אליס המתוארת בשאלה מבטיחה את תכונת ה integrity וגם תכונת ה authenticity, ולמרות שלא מעניין את אליס סודיות, היא גם מבטיחה סודיות.

ד. צורת הפעולה של אליס המתוארת בשאלה אינה מבטיחה את תכונת ה integrity ותכונת ה authenticity, כי אליס שולחת את ההודעה M בצורה גלויה, מה שנוגד את תכונות ה integrity ו authenticity.

<u>שאלה מספר 3:</u>

איזו מהטענות הבאות <u>אינה</u> נכונה לגבי מנגנון הבלוקצ'יין בביטקוין?

א. הבלוקצ'יין משתמש ב Merkle Tree כדי להבטיח את פרטיות העסקאות, כך שרק המשתתפים הישירים בעסקה יכולים לראות את פרטי העסקה המלאים

ב. ביטקוין משתמש במנגנון של hash, כדי לחשב את ה digest של בלוקים בבלוקצ׳יין.

ג. ביטקוין משתמש במנגנון של Proof of Work, שבו כורים מתחרים בפתרון חידה קריפטוגרפית מורכבת על מנת להוסיף בלוקים חדשים לשרשרת.

ד. ביטקוין מאפשר לכורים לבחור את העסקאות שיופיעו בבלוקים, ולכן, אם כורה רוצה, הוא יכול להרכיב בלוק של עסקאות שנותנות עמלות נמוכות, למרות שיש עסקאות אחרות שהכורה יכל לבחור בהן שנותנות עמלות גבוהות יותר.

<u>שאלה מספר 4:</u>

איזו מהטענות הבאות <u>אינה</u> נכונה?

א. אם CA הנפיק תעודה עבור שרת אינטרנט כלשהו (לא מדובר על שרת האינטרנט של הארגון שאליו שייך ה CA), ה CA הזה יכול לפענח תעבורת TLS בין שרת האינטרנט והלקוחות של שרת האינטרנט.

ב. בהינתן MAC של הודעה שחושב על ידי בוב, אליס אינה יכולה להוכיח לאחרים על בסיס MAC זה שההודעה נשלחה בהכרח על ידי בוב.

ג. תוקף מעוניין לגנוב cookie של סטודנטים באתר colman.ac.il. לשם כך הוא בונה אתר שלו בכתובת evil.co.il ושם סקריפט בעמוד הראשי של evil.co.il שניגש ל cookie של הלקוח באתר colman.ac.il ושולח את הcookie לתוקף. התקפה זו תיחסם על ידי הדפדפן.

ד. מתקפת XSS עשויה להיות תולדה של מתקפת SQL injection.

<u>שאלה מספר 5:</u>

אליס רצתה להבטיח את שלמותה (אמינות/אותנטיות) ואת סודיותה של הודעה שהיא שולחת. ולכן, היא הצפינה את ההודעה וחישבה MAC על ה ciphertext. באיזה שיטה עבדה אליס?

א. Encrypt then MAC.

ב. MAC and Encrypt.

ג. Sign then Encrypt.

ד. MAC then Decrypt.

<u>שאלה מספר 6:</u>

תכונת ה pre image resistance מוגדרת כ: (h הינה פונק׳ hash)

א. בהינתן d digest של הודעה אקראית, קשה למצוא הודעה m כך ש h(m)=d

ב. בהינתן הודעה אקראית m, קשה למצוא הודעה m' ששונה מ m, כך ש h(m) = h(m')

ג. בהינתן הודעה אקראית m, קשה למצוא הודעה m' ששונה מ m, כך ש h(m) שונה מ h(m')

ד. בהינתן d digest של הודעה אקראית, קשה למצוא d' digest כך ש d שונה מ d'

<u>שאלה מספר 7:</u>

איזו טענה היא הנכונה?

א. כדי לבצע התקפת ARP poisoning מספיק יכולת off-path.

ב. כדי לבצע התקפת ARP poisoning חייבים יכולת Eavesdropper.

ג. כדי לבצע התקפת ARP poisoning חייבים יכולת Man-in-the-Middle.

ד. כדי לבצע התקפת DNS poisoning חייבים יכולת Man-in-the-Middle.

<u>שאלה מספר 8:</u>

בהקשר של חתימה דיגיטלית לפי textbook RSA (כלומר ללא hash), יצא ש n = 33.

לוקחים את ההודעה 20 והחתימה הדיגיטלית שיצאה על הודעה זו הינה 26.

באיזה ערכי d ו e השתמשו?

א. e=3, d=7

ב. e=3, d=11

ג. e=7, d=11

ד. e=5, d=7

<u>שאלה מספר 9:</u>

מחליטים לשנות מנגנון הזדהות מול אתר אינטרנט, כך שימשיכו להשתמש בפונק׳ hash בטוחה קריפטוגרפית אך שבמקום להשתמש ב salt & pepper, יבצעו את אחד מהשינויים הבאים. איזה מהשינויים הבאים הכי יתרום לבטיחות (ויתרום יותר ביחס לשימוש רק ב salt) ועדיין יאפשר אימות מול אתר האינטרנט? (לאורך השאלה, כאשר מתייחסים ל i מתכוונים למספר שלם חיובי גדול מ 1)

א. כאשר משתמש נרשם למערכת, מחשבים hash על שרשור של ה salt (שהינו אקראי וארוך) והסיסמא של המשתמש, אך במקום ביצוע hash פעם אחת - עושים hash שוב ושוב i פעמים (בכל פעם שעושים שוב hash כוללים בקלט את הפלט שיצא בפעם הקודמת של הפעלת ה hash), ושומרים ב db את הusername, את ה salt ואת תוצאת ביצוע ה hash אחרי הפעם ה i.

ב. כאשר משתמש נרשם למערכת, מגרילים salt (שהינו אקראי וארוך) שוב ושוב i פעמים, כלומר, מגרילים פעם אחת ומתעלמים מהתוצאה, מגרילים פעם נוספת ומתעלמים מהתוצאה, ורק על ה salt שיוצא בפעם הi מחשבים hash פעם אחת על שרשור של הsalt והסיסמא של המשתמש ושומרים ב db את הusername, את ה salt ואת תוצאת ביצוע ה hash.

ג. כאשר משתמש נרשם למערכת, מגרילים ערך i אקראי, ומחשבים hash פעם אחת על שרשור של ערך הi שיצא והסיסמא של המשתמש ושומרים ב db את הusername, את ערך ה i ואת תוצאת ביצוע ה hash.

ד. כאשר משתמש נרשם למערכת, מגרילים salt (שהינו אקראי וארוך) שוב ושוב i פעמים, כלומר, מגרילים פעם אחת ומתעלמים מהתוצאה, מגרילים פעם נוספת ומתעלמים מהתוצאה. לוקחים את ה salt שיוצא בפעם הi ומחשבים hash על ה salt (שיצא בפעם הi), אך במקום ביצוע hash פעם אחת - עושים hash שוב ושוב i פעמים (בכל פעם שעושים שוב hash כוללים בקלט את הפלט שיצא בפעם הקודמת של הפעלת ה hash), ושומרים ב db את הusername, את ה salt ואת תוצאת ביצוע ה hash אחרי הפעם ה i.

<u>שאלה מספר 10:</u>

אילו מהסכנות הבאות עלולות להתרחש אם משתמשים באותם מפתחות בשני הכיוונים (מהלקוח לשרת ומהשרת ללקוח), והן אינן מתקיימות במידה ומשתמשים במפתחות שונים לכל כיוון?

א. מתקפת reflection, כלומר התוקף יכול לשלוח ללקוח הודעה שהלקוח שלח לשרת, כאילו השרת שלח אותה.

ב. התקפת One time pad.

ג. שיבוש ביטים בהודעה.

ד. מתקפת האזנה, כלומר, התוקף יוכל להסניף את ה plaintext.

--- סוף המבחן ---